

PRÉSENTATION DE LA MÉTHODOLOGIE DU PFE



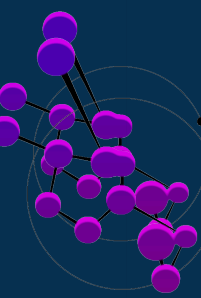
PROBLÈME DE SÉLECTION OPTIMALE DE CYBERDÉCEPTION

Nous considérons un système d'information représenté par un graphe d'attaque étiqueté $G=(V,E)$.

Dans ce graphe, l'attaquant part d'un ou plusieurs nœuds d'entrée et peut utiliser plusieurs techniques ATT&CK pour atteindre une ou plusieurs nœuds terminaux.

Une même technique ATT&CK peut être exécutée sur plusieurs actifs du système. De plus, une technique de cyberdéception peut être déployée à un emplacement différent de celui où la technique d'attaque est exécutée, Ces techniques ont des **coûts différents**, et nous disposons d'un **budget limité**.

Le problème consiste à sélectionner les mécanismes de cyberdéception et leurs emplacements de déploiement afin de minimiser le risque résiduel des nœuds terminaux, tout en respectant le budget disponible.



FORMALISATION DES DONNÉES D'ENTRÉE

Le système d'information comme graphe d'attaque étiqueté

$$G = (V, E)$$

avec :

$$V = \{T_{i,h}\}$$

où :

- T_i : technique d'attaque issue du framework MITRE ATT&CK ;
- h : actif d'exécution associé à cette technique.

Une arête :

$$(T_{i,h}, T_{j,h'}) \in E$$

signifie que :

la technique T_i est exécutée avant la technique T_j , autrement dit T_i est un **prédécesseur** de T_j dans le scénario d'attaque.

Chaque nœud $T_{i,h}$ possède un **dictionnaire d'attributs** :

$$Attr(T_{i,h}) = \left\{ \begin{array}{l} \textit{Tactique} : Tactic(T_i), \\ \textit{Outcomes} : O_{i,h}, \\ \textit{ProbabilitéLocale} : q_{i,h}, \\ \textit{Impact}_C : I_{i,h}^C, \\ \textit{Impact}_I : I_{i,h}^I, \\ \textit{Impact}_A : I_{i,h}^A, \\ \textit{Criticité} : Critical(h), \\ \textit{Accessibilité} : Accessible(h) \end{array} \right\}$$

avec :

- $Tactic(T_i)$: tactique MITRE ATT&CK à laquelle appartient T_i ;
- $O_{i,h}$: ensemble des outcomes produits par la réussite de T_i sur h ;
- $q_{i,h}$: probabilité locale de réussite ;
- $I_{i,h}^C, I_{i,h}^I, I_{i,h}^A$: impacts CIA ;
- $Critical(h)$: criticité de l'actif ;
- $Accessible(h)$: accessibilité de l'actif.

FORMALISATION DES DONNÉES D'ENTRÉE

Le système d'information comme graphe d'attaque étiqueté

Un nœud $T_{i,h}$ est un nœud d'entrée si :

$$Entry(T_{i,h}) = 1 \iff \begin{cases} Tactic(T_i) = InitialAccess \\ \mathbf{ET} \\ Accessible(h) = 1 \end{cases}$$

Un nœud $T_{i,h}$ est un nœud de terminaison si :

$$Terminal(T_{i,h}) = 1 \iff \begin{cases} Critical(h) = 1 \\ \mathbf{OR} \\ I_{i,h}^C \geq \theta_C \\ \mathbf{OR} \\ I_{i,h}^I \geq \theta_I \\ \mathbf{OR} \\ I_{i,h}^A \geq \theta_A \end{cases}$$

Autrement dit, $T_{i,h}$ est terminal si l'actif h est critique OR si l'impact sur au moins une propriété de sécurité C , I ou A dépasse son seuil critique correspondant.

FORMALISATION DES DONNÉES D'ENTRÉE

Des alternatives de cyberdéception

Pour chaque occurrence $T_{i,h}$ de la technique d'attaque T_i , exécutée sur l'actif h , on considère un ensemble de mécanismes de cyberdéception candidats :

$$D_{i,h} = \{d_{i,h,1}, d_{i,h,2}, \dots, d_{i,h,m}\}$$

où $D_{i,h}$ représente l'ensemble des mécanismes de cyberdéception pouvant être associés à la technique T_i lorsqu'elle est exécutée sur l'actif h .

Dans cette première formulation, nous posons l'hypothèse que les mécanismes candidats dépendent uniquement de la technique ATT&CK T_i , et non de son actif d'exécution h . Ainsi :

$$D_{i,h} = D_i \quad \forall h$$

avec :

$$D_i = \{d_{i1}, d_{i2}, \dots, d_{im}\}$$

Pour chaque occurrence $T_{i,h}$, on définit l'ensemble des couples admissibles :

$$C_{i,h} = \{(d, \ell) \mid d \in D_i, \ell \in L_{i,h,d}\}$$

où $C_{i,h}$ contient toutes les combinaisons possibles :

$$(\text{mécanisme de cyberdéception, emplacement de déploiement})$$

pour la technique T_i exécutée sur l'actif h .

Pour chaque occurrence $T_{i,h}$ et chaque mécanisme $d \in D_i$, on définit ensuite l'ensemble des emplacements de déploiement admissibles :

$$L_{i,h,d} = \{\ell_1, \ell_2, \dots, \ell_r\}$$

où $L_{i,h,d}$ représente les emplacements dans lesquels le mécanisme d peut être déployé pour agir contre T_i exécutée sur l'actif h .

Exemple

Pour la technique :

$$T_i = T1003 \quad \text{Credential Dumping}$$

on peut avoir :

$$D_{T1003} = \{FakeCredentials, HoneyCredentials, CredentialStoreMasking\}$$

Pour une occurrence exécutée sur un contrôleur de domaine DC :

$$L_{T1003,DC,HoneyCredentials} = \{DC, ActiveDirectory\}$$

Ainsi, les mécanismes candidats dépendent de la technique T_i , tandis que leurs emplacements de déploiement dépendent de l'occurrence $T_{i,h}$ et du mécanisme d .

FORMALISATION DES DONNÉES D'ENTRÉE

Un effet de déception pour chaque placement admissible

Pour chaque occurrence $T_{i,h}$ et chaque couple admissible :

$$(d, \ell) \in C_{i,h}$$

on évalue l'effet attendu de la déception :

$$DeceptionEffect(T_i, h, d, \ell) = P_{engage}(T_i, h, d, \ell) \times Effectiveness_{prog}(T_i, h, d, \ell)$$

où $DeceptionEffect(T_i, h, d, \ell)$ représente :

La proportion attendue de la progression de l'attaque qui est empêchée, détournée ou contenue lorsque le mécanisme d est déployé à l'emplacement ℓ pour agir contre T_i exécutée sur l'actif h .

Un coût

Pour chaque mécanisme de cyberdéception d et chaque emplacement de déploiement admissible ℓ , on définit un coût total :

$$Cost(d, \ell; H)$$

Ce coût représente les ressources nécessaires au déploiement, au fonctionnement et à la maintenance du mécanisme d à l'emplacement ℓ , pendant l'horizon H .

Dans cette première formulation, nous supposons que le coût ne varie pas selon l'emplacement de déploiement. Ainsi :

$$Cost(d, \ell; H) = Cost(d; H) \quad \forall \ell$$

Hypothèse : pour un même mécanisme d , le coût total est identique pour tous les emplacements admissibles.

Un budget

Le modèle considère également un budget total disponible, noté :

$$B_{total}$$

B_{total} représente le montant global fixé ou fourni par l'organisation pour le déploiement et le maintien de l'ensemble des techniques de cyberdéception.

FORMULATION DU PROBLÈME

Étant donné un graphe d'attaque :

$$G = (V, E)$$

un ensemble de mécanismes de cyberdéception, leurs emplacements possibles, leurs coûts et leurs effets de déception, quelle combinaison de déploiements faut-il sélectionner pour minimiser le risque résiduel des actifs critiques sans dépasser le budget disponible ?

Quels quadruplets (T_i, h, d, l) faut-il sélectionner afin de minimiser les risques résiduels des nœuds terminaux correspondant à des techniques exécutées sur des actifs critiques tout en respectant le budget disponible ?

VARIABLE DE DÉCISION : QU'EST-CE QUE LE MODÈLE DOIT DÉTERMINER ?

Pour chaque occurrence $T_{i,h}$ d'une technique d'attaque et chaque couple admissible $(d, \ell) \in C_{i,h}$:

- i désigne l'indice de la technique d'attaque T_i ;
- h désigne l'actif sur lequel T_i est exécutée ;
- d désigne un mécanisme de cyberdception candidat appartenant à D_i ;
- ℓ désigne un emplacement de déploiement admissible appartenant à $L_{i,h,d}$.

On définit la variable de décision binaire :

$$y_{i,h,d,\ell} \in \{0, 1\}$$

avec :

$$y_{i,h,d,\ell} = \begin{cases} 1 & \text{si le mécanisme } d \text{ est sélectionné et déployé à } \ell \\ & \text{pour agir contre } T_i \text{ exécutée sur l'actif } h, \\ 0 & \text{sinon.} \end{cases}$$

Signification

$y_{i,h,d,\ell}$ représente la décision de sélectionner un mécanisme de cyberdception d et son emplacement de déploiement ℓ , pour chaque occurrence d'attaque $T_{i,h}$.

NOTATIONS ET PARAMÈTRES DU MODÈLE

Symbole	Définition	Rôle
$\mathcal{T} = \{T_{i,h}\}$	Ensemble des occurrences de techniques considérées dans le graphe	Ensemble sur lequel les décisions de cyberdéception sont prises
$\mathcal{T}_{term}$	Ensemble des nœuds terminaux	Définit les nœuds dont les risques sont minimisés
$\mathcal{D}_i$	Ensemble des mécanismes de cyberdéception candidats pour T_i	Alternatives de défense
$L_{i,h,d}$	Emplacements admissibles pour déployer d contre $T_{i,h}$	Alternatives de placement
$\mathcal{C}_{i,h}$	Ensemble des couples admissibles (d, ℓ)	Domaine des décisions pour $T_{i,h}$
$y_{i,h,d,\ell}$	Variable binaire de sélection	Inconnue du problème
$P_{engage}(T_{i,h}, d, \ell)$	Probabilité d'engagement avec la déception	Calcul de l'effet défensif
$Effectiveness_{prog}(T_{i,h}, d, \ell)$	Efficacité pour réduire la progression	Calcul de l'effet défensif
$DE_{i,h,d,\ell}$	Effet de déception attendu	Quantifie l'effet du déploiement
$\Gamma_{i,h}(y)$	Facteur résiduel de continuation	Réduit la propagation depuis le nœud
$\pi_{u \rightarrow (i,h)}$	Probabilité de transition en cas de divergence	Distribue la propagation entre les branches
$A_{i,h}(y)$	Probabilité d'atteindre $T_{i,h}$	Atteignabilité du nœud
$q_{i,h}$	Probabilité locale de réussite	Permet de passer de A à P
$P_{i,h}(y)$	Probabilité propagée de réussite	$P_{i,h} = A_{i,h} q_{i,h}$
$I_{i,h}$	Impact agrégé associé au nœud	Intervient dans le calcul du risque
$R_{i,h}(y)$	Risque résiduel du nœud	$R_{i,h} = P_{i,h} I_{i,h}$
$Cost(d; H)$	Coût du mécanisme d	Contrainte budgétaire
B_{total}	Budget total disponible	Limite les déploiements

LE PROBLÈME D'OPTIMISATION

$$T_{\text{term}} = \{T_{i,h} \in \mathcal{T} \mid \text{Terminal}(T_{i,h}) = 1\}$$

(ensemble des nœuds terminaux)

$$\min_y \quad \left(R_{i_1,h_1}(y), R_{i_2,h_2}(y), \dots, R_{i_m,h_m}(y) \right) \quad (P)$$

$$\text{s.c.} \quad \begin{cases} \sum_{T_{i,h} \in \mathcal{T}} \sum_{(d,\ell) \in C_{i,h}} y_{i,h,d,\ell} \text{Cost}(d,\ell; H) \leq B_{\text{total}} \\ \sum_{(d,\ell) \in C_{i,h}} y_{i,h,d,\ell} \leq 1, \quad \forall T_{i,h} \in \mathcal{T} \\ y_{i,h,d,\ell} \in \{0, 1\} \end{cases}$$

Élément	Contenu
Entrées	$G, \mathcal{T}, \mathcal{T}_{\text{term}}, C_{i,h}, DE_{i,h,d,\ell}, \text{Cost}(d,\ell; H), B_{\text{total}}$
Inconnue	$y_{i,h,d,\ell}$
Objectif	Minimiser simultanément les risques résiduels des nœuds terminaux
Contraintes	Coût total $\leq$ budget ; au maximum un couple (d,ℓ) par occurrence $T_{i,h}$

$$R_{i,h}(y) = P_{i,h}(y) \times I_{i,h}, \quad T_{i,h} \in \mathcal{T}_{\text{term}}$$

$$DE_{i,h,d,\ell} = P_{\text{engage}}(T_i, h, d, \ell) \times \text{Effectiveness}_{\text{prog}}(T_i, h, d, \ell)$$

MÉTRIQUE : Calcul du risque d'un nœud d'attaque

Le risque dépend de y car une déception placée sur un parent réduit la probabilité de continuation vers les nœuds suivants.



1 Définition

Le risque d'un nœud d'attaque $T_{i,h}$ mesure le niveau de menace associé à cette occurrence dans le graphe.

$$R_{i,h}(y) = P_{i,h}(y) \times I_{i,h}$$

- $P_{i,h}(y)$: probabilité propagée que $T_{i,h}$ soit atteint et réussi
- $I_{i,h}$: impact agrégé associé au nœud $T_{i,h}$

2 Effet de la déception

$$DeceptionEffect(T_{i,h}, d, \ell) = P_{engage}(T_{i,h}, d, \ell) \times Effectiveness_{prog}(T_{i,h}, d, \ell)$$

$$\Gamma_{i,h}(y) = 1 - \sum_{d \in D_i} \sum_{\ell \in L_{i,h,d}} DeceptionEffect(T_{i,h}, d, \ell) y_{i,h,d,\ell}$$

- $y_{i,h,d,\ell} = 1$ si le mécanisme est déployé à l'emplacement ℓ contre $T_{i,h}$, 0 sinon.
- $\Gamma_{i,h}(y)$: proportion résiduelle de l'attaque qui poursuit après $T_{i,h}$.
- La déception agit surtout sur la continuation vers les nœuds enfants.

3 Probabilité locale de réussite

La probabilité locale dépend de la technique et de l'actif d'exécution h :

$$q_{i,h} = w_O C_{a,i,h} + w_H H_{i,h} + w_F F_{i,h}, \quad w_O + w_H + w_F = 1$$

$C_{a,i,h}$	: convertibilité avec les capacités de l'attaquant
$H_{i,h}$	: information historique / fréquence observée
$F_{i,h}$	: faisabilité technique d'exécution

i Si aucune pondération n'est justifiée : $q_{i,h} = \frac{C_{a,i,h} + H_{i,h} + F_{i,h}}{3}$

4 Atteignabilité et propagation

$\pi_{(u,g) \rightarrow (i,h)}$: probabilité de transition de $T_{u,g}$ vers $T_{i,h}$

Sans données :

$$\pi_{(u,g) \rightarrow (i,h)} = \frac{1}{|Children(T_{u,g})|}$$

$$\sum_{T_{i,h} \in Children(T_{u,g})} \pi_{(u,g) \rightarrow (i,h)} = 1$$

Cas de divergence (un seul parent $T_{u,g}$) :

$$A_{i,h}^{div}(y) = P_{u,g}(y) \times \Gamma_{u,g}(y) \times \pi_{(u,g) \rightarrow (i,h)}$$

Cas de convergence (plusieurs parents) :

$$A_{i,h}^{conv}(y) = 1 - \prod_{T_{u,g} \in Parents(T_{i,h})} (1 - \tilde{P}_{(u,g) \rightarrow (i,h)}(y))$$

avec $\tilde{P}_{(u,g) \rightarrow (i,h)}(y) = P_{u,g}(y) \Gamma_{u,g}(y) \pi_{(u,g) \rightarrow (i,h)}$ si le parent est divergent,
sinon $\tilde{P}_{(u,g) \rightarrow (i,h)}(y) = P_{u,g}(y) \Gamma_{u,g}(y)$.

$$P_{i,h}(y) = A_{i,h}(y) \times q_{i,h}$$

avec $A_{i,h}(y) = 1$ si $Entry(T_{i,h}) = 1$; sinon $A_{i,h}(y) = A_{i,h}^{div}(y)$ ou $A_{i,h}^{conv}(y)$ selon le cas.

Chaîne de propagation



5 Calcul analytique de l'impact

L'impact $I_{i,h}$ mesure la gravité associée au nœud $T_{i,h}$.

$$I_{i,h} = w_C I_{i,h}^C + w_I I_{i,h}^I + w_A I_{i,h}^A$$

$$w_C + w_I + w_A = 1$$

i Si aucune pondération n'est justifiée :

$$I_{i,h} = \frac{I_{i,h}^C + I_{i,h}^I + I_{i,h}^A}{3}$$

Légende :

w_C : poids de la confidentialité

w_I : poids de l'intégrité

w_A : poids de la disponibilité



Formule récapitulative

$$y_{i,h,d,\ell} \rightarrow DeceptionEffect \rightarrow \Gamma_{i,h}(y) \rightarrow A_{i,h}(y) \rightarrow P_{i,h}(y) \rightarrow R_{i,h}(y)$$

$$R_{i,h}(y) = P_{i,h}(y) \times I_{i,h}$$